Compliance & Vulnerability Management Tool

End-to-end architectural overview · Enterprise Grade

- **L1 – Data Ingestion**: Network scanners, endpoint agents, API connectors, log aggregators, and container/IaC scanners feeding into a normalized event bus
- **L2 – Processing & Analysis**: Vulnerability correlation engine, compliance policy engine (OPA/Rego), ML-based risk scoring, attack path analysis using graph traversal, and drift detection
- **L3 – Data Storage**: Separate stores for assets (PostgreSQL/CMDB), vulnerability lifecycle (TimescaleDB), immutable evidence (S3), graph relationships (Neo4j), and search/cache (Elasticsearch + Redis)
- **L4 – Orchestration**: Alerting/escalation, remediation ticket sync (Jira/ServiceNow), SOAR playbooks, scan scheduling, and auditor sign-off workflows
- **L5 – API Gateway**: REST/GraphQL API, WebSocket streams, OAuth2/SAML identity, and webhook dispatch
- **L6 – Presentation**: Executive dashboard, analyst vuln workspace, compliance console, attack path visualizer, and report builder

L1 - DATA INGESTION & COLLECTION

INPUT LAYER

MULTI-SOURCE INGESTION BUS

❖ **Network Scanner**

Nmap/Nessus-style active scanning. Port discovery, service fingerprinting, topology mapping.

TCP/UDP/ICMP/IPV4/V6:4444

❖ **Agent Collectors**

Lightweight endpoint agents deployed on hosts. OS inventory, patch levels, config state, process list.

WINDOWS/LINUX/MACOS

❖ **API Connectors**

Cloud provider APIs (AWS, Azure, GCP), SaaS integrations (Jira, ServiceNow), CI/CD hooks.

REST/GRAPHQL/WEBHOOKS

❖ **Log Aggregator**

Syslog, SIEM forwarding, audit trail ingestion. Supports Splunk, Elastic, Datadog pipelines.

SYSLOG/CEF/LEEF

❖ **Container & IaC Scanner**

Docker image scanning, Terraform/K8s manifest analysis, SBOM generation from build artifacts.

SBOM/OCI/HELM

↓ NORMALIZED EVENT STREAM · KAFKA TOPICS · SCHEMA VALIDATED ↓

L2 - PROCESSING & ANALYSIS ENGINE

CORE LOGIC

❖ **Vulnerability Correlation Engine**

Maps raw scan data against CVE/NVD, vendor advisories, and EPSS exploit probability scores. Deduplicates findings across sources. Generates asset-centric risk views with asset criticality weighting.

CVE/CVSS V3.1/EPSS/NVD/VEX

❖ **Compliance Policy Engine**

Rule-based evaluation against control frameworks. Automated evidence collection, gap analysis, and deviation tracking. Policy-as-code via OPA/Rego.

SOC 2/ISO 27001/NIST CSF/PCI-DSS/HIPAA

❖ ML Risk Scorer

Contextual risk scoring using asset exposure, exploitability, blast radius, and business context. Anomaly detection for behavioral deviations.

XGBOOST/ISOLATION FOREST

❖ Attack Path Analyzer

Graph-based lateral movement modeling. Identifies choke points, privilege escalation paths, and blast radius from each vulnerability node.

NEO4J/MITRE ATT&CK

❖ Trend & Drift Detector

Tracks compliance posture over time. Detects configuration drift, SLA breach predictions, and regression alerts on remediation velocity.

TIME-SERIESSLA TRACKING

↓ ENRICHED FINDINGS · RISK SCORES · COMPLIANCE DELTAS ↓

L3 - DATA STORAGE & STATE MANAGEMENT

PERSISTENCE

❖ Asset Inventory DB

Canonical CMDB-style asset registry. Hardware, software, cloud resources, relationships, and ownership metadata.

POSTGRESQL/CMDB

❖ Vulnerability Store

Time-versioned vuln findings with full lifecycle state: open, in-review, accepted, mitigated, resolved. Linked to CVE metadata.

TIMESCALEDB/SLA STATE

❖ Evidence Repository

Immutable audit-grade evidence store for compliance artifacts. Screenshots, configs, logs with cryptographic chain of custody.

S3-COMPATIBLE/SHA-256

❖ Graph Database

Asset relationship and attack path graphs. Supports complex traversal queries for blast radius and dependency chain analysis.

NEO4J/CYPHER

❖ Cache & Search Index

Redis for real-time dashboard state. Elasticsearch for full-text search across findings, policies, and audit logs.

REDIS/ELASTICSEARCH

↓ QUERY RESULTS · AGGREGATIONS · LIVE EVENTS ↓

L4 - ORCHESTRATION & WORKFLOW AUTOMATION

AUTOMATION

❖ Alert & Escalation Engine

Threshold-based and ML-driven alerting. Severity routing, on-call escalation chains, deduplication and alert fatigue controls.

PAGERDUTY/OPSGENIE

❖ Remediation Tracker

Auto-creates tickets from critical findings. Bidirectional sync with Jira/ServiceNow. SLA countdown, ownership assignment, closure verification.

JIRA/SERVICENOW/LINEAR

❖ Playbook Engine

SOAR-style automated response playbooks. Conditional logic, approval gates, rollback capability. Supports manual override and exception workflows.

SOAR/DAG-BASED

❖ Scan Scheduler

Cron-based and event-driven scan orchestration. Respects maintenance windows, rate limits, and concurrency caps per target zone.

CELERY/AIRFLOW

❖ Audit & Sign-off Workflow

Evidence review and sign-off flows for auditors. Controls-to-evidence linking, auditor workspace, finding dispute management.

E-SIGNATURE/AUDIT TRAIL

↓ PROCESSED DATA · API RESPONSES · REAL-TIME EVENTS ↓

L5 - API GATEWAY & INTEGRATION LAYER

INTERFACES

❖ API Gateway

Rate limiting, JWT/OAuth2 auth, request routing, versioning, and API key management. Powered by Kong or AWS API Gateway.

OAUTH2/MTLS/RATE LIMIT

❖ REST / GraphQL API

Primary developer API. RESTful endpoints for all resources, GraphQL for flexible querying. OpenAPI 3.0 spec published.

OPENAPI 3.0/PAGINATION

❖ WebSocket Stream

Real-time push of live scan progress, new findings, and dashboard metric updates to connected browser clients.

SOCKET.IO/SSE FALLBACK

❖ Identity & Access

RBAC with granular permission scopes. SSO via SAML2/OIDC. MFA enforcement. Just-in-time provisioning from Okta/Azure AD.

SAML2/OIDC/SCIM

❖ Webhook Dispatcher

Outbound webhooks for finding events, scan completions, and compliance state changes. Retry logic, HMAC signing, delivery logs.

HMAC/RETRY QUEUE

↓ RENDERED VIEWS · USER INTERACTIONS ↓

L6 - PRESENTATION & REPORTING LAYER

USER INTERFACE

❖ Executive Dashboard

Risk posture KPIs, compliance score by framework, SLA adherence rates, trend sparklines. Board-ready summaries.

REACT/D3.JS

❖ Vuln Workspace

Analyst-grade finding explorer. Advanced filters, asset drill-down, CVE detail cards, exploitability timelines, and bulk triage.

FULL-TEXT SEARCH/BULK ACTIONS

❖ Compliance Console

Control-by-control status view per framework. Evidence upload, auditor comments, exception management, and remediation plans.

CONTROLS LIBRARY/EVIDENCE MGMT

❖ Attack Path Visualizer

Interactive graph view of attack paths and blast radius. Node inspection with CVE details. Path highlighting and export to PDF/PNG.

CYTOSCAPE.JS/FORCE-GRAPH

❖ Report Builder

Template-driven reports for auditors, executives, and engineering. Scheduled delivery. Supports PDF, XLSX, CSV exports.

PDF EXPORT/SCHEDULED

CROSS-CUTTING CONCERNS

- **Encryption**
  AES-256 at rest, TLS 1.3 in transit, field-level encryption for PII/secrets
- **Observability**
  Distributed tracing (Jaeger), metrics (Prometheus/Grafana), structured logging (ELK)
- **Multi-tenancy**
  Org-level data isolation, tenant-scoped RBAC, namespace separation in K8s
- **HA & DR**
  Active-active multi-region, RTO <15min, RPO <1hr, automated failover
- **Audit Logging**
  Immutable audit log for all user actions, config changes, and API calls. 7-year retention

COMPLIANCE FRAMEWORKS

- **SOC 2 Type II**
  Security, Availability, Confidentiality TSCs
- **ISO 27001:2022**
  93 controls, Annex A mappings
- **NIST CSF 2.0**
  Govern, Identify, Protect, Detect, Respond, Recover
- **PCI-DSS v4.0**
  12 requirements, network segmentation evidence
- **HIPAA / HITRUST**
  ePHI safeguards, BAA management
- **FedRAMP / CMMC**
  Government cloud controls baseline

VULNERABILITY SOURCES

- **NVD / CVE**
  Synced every 2hrs via NVD API 2.0
- **KEV (CISA)**
  Known exploited vulnerabilities prioritization
- **Vendor Advisories**
  Microsoft, Red Hat, Oracle, Apache, etc.
- **Threat Intel Feeds**
  Commercial TI, ISAC sharing, OSINT

DEPLOYMENT

- **Kubernetes**
  Helm charts, HPA, PDB, namespace isolation
- **Multi-cloud**
  AWS primary, GCP/Azure failover regions
- **On-premise**
  Air-gapped deployments for government / regulated industries